Audit de sécurité et RGPD final : Weekli

Projet	Weekli (monorepo `apps/server`, `apps/web`, `apps/video`, `packages/core`)
Date	29 octobre 2026
Auditeur	securite-senior (aucun code modifié, rien commité)
Branche auditée	`feat/weekli-v1`, commit `c09e359` (PR Souf-F/weekli#6), 43 commits sur la branche, 46 dans tout l'historique local
Périmètre	Code (server, web, video, core, scripts, CI, Dockerfile), historique Git complet, dépôt GitHub `Souf-F/weekli` en lecture seule, `npm audit`, serveur local `http://localhost:8788` en tests dynamiques non authentifiés
Cibles testées	Fichiers locaux ; historique Git ; API GitHub (lecture) ; bundle de production recompilé dans un dossier temporaire ; serveur local (en-têtes, CSP, COOP et COEP, CSRF par Origin, débit, 401, OAuth, métadonnées MCP, fichiers exposés) ; navigateur Chrome headless avec un profil vierge (réseau, console, stockage, cookies)
Hors périmètre	Aucune URL de production (rien n'est déployé) ; aucun test authentifié (consigne : ni compte ni session de Soufiane)
Verdict global	**OK, avec réserves MINEUR (mis à jour le 2 novembre 2026, voir section 11) : 0 BLOQUANT, 0 MAJEUR après vérification des corrections. Verdict du 29 octobre, avant corrections : A CORRIGER : 0 BLOQUANT, 1 MAJEUR, 11 MINEUR nouveaux ; audit initial : 6 MAJEUR sur 6 corrigés, 13 MINEUR sur 17 corrigés, 2 partiels (m3, m12), 2 ouverts (m13, m16), plus le résidu B14 de M3**

Aucun secret réel exposé. Le fichier `apps/server/.dev.vars` (secrets locaux réels) n'est ni suivi par Git, ni présent dans l'historique, ni poussé ; il est exclu par `.git/info/exclude:9` et `.dockerignore`. Son contenu n'a pas été affiché.

Rappel : cet audit vérifie la conformité technique et documentaire. Il ne remplace pas l'avis d'un juriste ou d'un DPO.

1. Synthèse

Sévérité	Nouveaux constats	Restes de l'audit initial
BLOQUANT	0	0
MAJEUR	1	0
MINEUR	11	5 (M3 résiduel B14, m3, m12 partiels ; m13, m16 ouverts)

Les 3 risques principaux :

1. **Déni de service par expression régulière (N1)** : le masquage des secrets a un coût quadratique ; un fichier de 99 Ko de son propre repo public coûte 8,5 s de CPU par lecture, sans plafond de taille avant masquage pour le README et les diffs.
2. **Page Confidentialité encore inexacte sur quelques points (N2, N3)** : journaux décrits comme sans donnée personnelle alors que des erreurs Octokit complètes y sont écrites, cookie de consentement MCP de 30 jours non listé, Microsoft présenté comme sous-traitant encadré alors qu'aucun contrat n'existe.
3. **Cache vocal partagé et quotas KV (N4)** : un compte GitHub quelconque peut écrire jusqu'à 1 440 audios par jour dans KV et sonder si une phrase a déjà été synthétisée par quelqu'un.

Points forts constatés : effacement complet réel (KV, grants MCP, Durable Objects, toutes les sessions, autorisation GitHub révoquée), export JSON, identité par id numérique partout, token GitHub chiffré et lié à l'id (AAD) dans les props MCP, Durable Objects détruits après 24 h d'inactivité et contrôlés par propriétaire, chiffrement versionné avec AAD et clé HMAC dérivée par HKDF, polices hébergées localement (aucune requête tierce mesurée), CSP stricte sans `unsafe-inline`, COOP et COEP actifs (`crossOriginIsolated` vrai), mode démo absent du build même avec `VITE_DEMO=1`, `npm audit` à 0, 503 tests verts.

2. Éléments sensibles trouvés

Élément	Emplacement	Statut
Secrets locaux réels	`apps/server/.dev.vars` (mode 600)	Non suivi, absent de l'historique et de GitHub, exclu de Docker. Contenu non lu. OK
Copies de build Wrangler	`apps/server/.wrangler/tmp/dev-*/index.js` (gitleaks : motifs `private-key`)	Bundles de dépendances locaux, exclus par `.git/info/exclude`, jamais suivis. Sans risque
`TrustedClientToken` d'edge-tts	`apps/server/src/lib/voix-gec.ts:34` (`6A5A****`)	Constante publique du projet libre edge-tts, pas un secret de Weekli. Signalée par gitleaks, non sensible
Jetons de test	`apps/server/src/mcp/__tests__/aide.ts:8` (`gho_****`), `agent.test.ts:40`	Factices
URL avec identifiants	`apps/server/src/lib/__tests__/domaines.test.ts:46` (commit `35c41ee`)	Factice (trufflehog : non vérifiée)
Client ID OAuth GitHub	Redirection de `/auth/login` (`Ov23****`)	Public par conception OAuth, non secret
Email personnel de l'auteur	Métadonnées des 46 commits (`sfec****@gmail.com`)	Toujours présent, voir m13

Élément	Emplacement	Statut
Clé API Anthropic de l'utilisateur	`sessionStorage` (par défaut) ou `localStorage`, clé `weekli.cle`	Par conception, avertissement présent (m10 corrigé)

---

3. Nouveaux constats

MAJEUR

> **MAJEUR N1. packages/core/src/masquage.ts:9, posts/tuto.ts:140 et :152, github.ts:154 : masquage des secrets en temps quadratique, sur des textes non plafonnés**

- Problème : le motif `\bsk-(?=[A-Za-z0-9_-]*\d)[A-Za-z0-9_-]{32,}` relance une anticipation jusqu'à la fin de la suite de caractères à chaque occurrence de `sk-`. Sur une chaîne `sk-sk-sk-...` sans chiffre, le coût est quadratique. Or `masquerSecrets` est appliqué avant la troncature, sur le texte entier : fichiers du tuto jusqu'à 100 Ko chacun (12 fichiers), README brut sans aucun plafond (`tuto.ts:152`, l'API GitHub en mode raw peut renvoyer plusieurs Mo), et patchs de commits (`github.ts:154`).
- Preuve : même moteur V8 que Workers, script `node` sur le motif exact : 9 Ko : 81 ms ; 24 Ko : 537 ms ; 99 Ko : 8 514 ms. Le motif PEM et les autres restent linéaires.
- Scénario d'attaque : n'importe quel titulaire d'un compte GitHub crée un repo public avec 12 fichiers de 99 Ko et un README de quelques Mo remplis de `sk-`, puis appelle `POST /api/posts/donnees` (type `tuto`) ou l'outil MCP `preparer_post`, 60 fois par minute. Chaque appel consomme la limite de CPU du Worker (coût facturé, isolat bloqué pour les autres requêtes qu'il sert), ou bloque le Durable Object. Exploitation dynamique non testée (nécessite une session authentifiée, hors consigne).
- Correction : (1) réécrire le motif sans anticipation : `\bsk-[A-Za-z0-9_-]{32,}` puis vérifier la présence d'un chiffre dans la fonction de remplacement ; (2) tronquer avant de masquer avec une marge : `masquerSecrets(texte.slice(0, plafond + 256)).slice(0, plafond)` dans `tuto.ts` (fichiers et README) et `github.ts` (patchs, README) ; (3) ajouter un test de performance (100 Ko de `sk-` en moins de 50 ms).
- Agent concerné : backend-senior.

MINEUR

> **MINEUR N2. apps/web/src/pages/Legal/Confidentialite.tsx:169, :160 et :85 : trois inexactitudes de la page Confidentialité**

- « Weekli n'y écrit aucune donnée personnelle : seulement des noms d'erreur » : faux pour `routes/api.ts:54` (`console.error("API :", err)` journalise l'erreur Octokit entière, dont l'URL `/repos/<login>/<repo>`), `routes/auth.ts:65`, `routes/oauth-mcp.ts:38` et `mcp/outils-captures.ts:33` (URL de la page capturée).
- « Deux cookies strictement nécessaires » : la bibliothèque OAuth pose aussi `__Host-oauth-consent`, `__Host-oauth-upstream` (10 min) et `__Host-oauth-approvals` (consentement mémorisé, 30 jours, `oauth-provider.js:2149` et `:2359`).
- « 60 secondes dans le limiteur de débit » : le quota vocal garde aussi `voix-quota:<id>` 2 heures dans KV (`lib/voix.ts:119` et `:122`).
- Correction : journaliser `err.name` et le statut seulement (comme `donnees.ts:13`), ou corriger la phrase ; lister les cookies OAuth ; ajouter la ligne du quota vocal. Agent : backend-senior (journaux), frontend-

senior (texte).

> **MINEUR** **N3. apps/server/src/lib/voix.ts:11 à 13 et :45 à 52, Confidentialite.tsx:127 à 129 : Microsoft sans contrat, usage non officiel**

Microsoft est présenté comme sous-traitant « Cadre de protection des données UE-États-Unis », mais Weekli n'a aucun contrat (article 28) ni accord d'utilisation pour le service de lecture d'Edge, appelé en se présentant comme l'extension Edge (`Origin` d'extension, `User-Agent` Edge, jeton Sec-MS-GEC). Risque accepté par Soufiane (changelog du 25 octobre) et données limitées (texte de voix off, ni identité ni IP). Correction : formuler « destinataire, sans contrat, usage non officiel » plutôt que sous-traitant encadré, et prévoir Azure Speech (contrat et DPA) avant toute ouverture publique. Avis d'un juriste recommandé. Agent : architecte (décision), frontend-senior (texte).

> **MINEUR** **N4. apps/server/src/routes/api.ts:279 à 283, lib/voix.ts:108 à 123 : cache vocal partagé, oracle et volume**

- Un appel dont le texte est déjà en cache répond aussitôt sans consommer le quota horaire : un utilisateur peut savoir si une phrase exacte a déjà été synthétisée par quelqu'un (oracle de faible portée, il faut deviner le texte exact).
- Chaque phrase nouvelle écrit deux valeurs KV (audio jusqu'à 2 Mo gardé 90 jours, compteur). Avec 60 phrases par heure et par compte, un seul compte GitHub peut écrire 2 880 fois par jour et stocker plusieurs centaines de Mo en 90 jours. Sur l'offre gratuite Workers (1 000 écritures KV par jour, 1 Go), cela suffit à bloquer les connexions de tous. Offre réelle non vérifiée.
- Correction : compter aussi les réponses servies par le cache dans un plafond (ou un quota quotidien), plafonner le volume du cache (TTL plus court, 30 jours), surveiller les quotas KV avant déploiement. Agent : backend-senior.

> **MINEUR** **N5. apps/web/src/pages/Reglages/PanneauDonnees.tsx:58 et :77, pages/Tableau/Tableau.tsx:38 : effacement local partiel et texte du panneau inexact**

« Supprimer mes données » n'efface que la clé API et les préférences (`lib/reglages.ts:50` à :59). Restent : IndexedDB `weekli-pub` (images importées et logo), cache vocal du navigateur, `localStorage` du dernier repo et ancien style. La page Confidentialité le dit, pas le panneau. Le panneau annonce aussi « ton token GitHub [...] pendant 90 jours » (réel : session 8 h, autorisation MCP 30 jours) et oublie les pubs. Correction : effacer aussi ces bases et clés (`indexedDB.deleteDatabase`), aligner le texte. Agent : frontend-senior.

> **MINEUR** **N6. packages/core/src/github.ts:125 : README non masqué hors tuto ; liste de formats courte**

`detailsRepo` renvoie le README tronqué sans `masquerSecrets` : il sert à `details_repo`, `preparer_pub`, `proposer_post_projet` et `preparer_post` (types présentation, coulisses, leçon). Par ailleurs `masquage.ts` ne reconnaît pas `sk_live_` et `rk_live_` (Stripe), `AIza` (Google), `npm_`, `glpat-`, `SG.` (SendGrid), les JWT `eyJ`. Ces contenus sont déjà publics sur GitHub ; l'enjeu est de ne pas les recopier dans Claude ou dans un post. Correction : masquer aussi dans `detailsRepo` et ajouter ces préfixes à longueur fixe (sans motif générique). Agent : backend-senior.

> **MINEUR** **N7. packages/core/src/prompts.ts:130 : balise `<donnees_post>` contournable en mode clé API**

Le JSON est inséré entre `<donnees_post>` et `</donnees_post>` ; `JSON.stringify` n'échappe pas `<`, donc un README contenant `</donnees_post>` suivi de consignes sort du cadre. Impact limité au texte généré pour l'utilisateur lui-même (aucun outil côté navigateur). Correction : `JSON.stringify(...).replaceAll("<", "\\u003c")`. Agent : backend-senior.

> **MINEUR** **N8. apps/web/src/pages/Legal/MentionsLegales.tsx:20 : téléphone de l'hébergeur absent**

La LCEN (article 6, III) demande le nom, l'adresse et le numéro de téléphone de l'hébergeur. Correction : ajouter le numéro de Cloudflare, Inc. Agent : frontend-senior.

> **MINEUR** **N9. packages/core/src/github.ts:130 : `detailsCommit` sans contrôle de visibilité**

`commitsRepo`, `detailsRepo` et la lecture du tuto refusent un repo privé ; `detailsCommit` non. Sans effet avec le scope `read:user` (les tokens d'une OAuth App ne lisent pas le privé), mais incohérent si le scope change. Correction : même contrôle `infos.private`. Agent : backend-senior.

> **MINEUR** **N10. apps/server/wrangler.jsonc : aucune limite de CPU par requête**

Pas de `limits.cpu_ms` : la limite par défaut s'applique. Avec N1, une limite explicite (par exemple 5 000 ms) borne le coût d'un abus. Agent : architecte.

> **MINEUR** **N11. Fichiers sensibles testés par URL : réponse 200 de repli SPA**

`/.env`, `/.git/config`, `/.dev.vars`, `/backup.sql`, `/phpinfo.php`, `/.DS_Store`, `/server-status`, `/wrangler.jsonc`, `/assets/*.js.map` renvoient 200 avec `index.html` (783 octets), jamais le fichier. Aucun contenu sensible, mais un scanner y verra des faux positifs. Correction facultative : 404 pour les chemins commençant par un point. Agent : backend-senior.

---

4. Suivi de l'audit initial (24 octobre 2026)

#	Constat initial	Statut	Vérification
M1	Effacement incomplet, promesse inexacte	**Corrigé**	`lib/donnees.ts` : brouillons, pubs, domaines, style, anciennes clés par login ; `revokeGrant` de tous les grants (pagination) ; destruction des Durable Objects listés dans `mcp:<id>` ; révocation de l'autorisation GitHub (`DELETE /applications/{id}/grant`) ; fermeture de toutes les sessions indexées ; étapes indépendantes, 500 et relance si KV échoue. Texte de la page aligné. Reste local : N5
M2	Token GitHub en clair et sans durée dans les Durable Objects	**Corrigé**	`lib/props.ts` : token chiffré AES-GCM, AAD liée à l'id ; email retiré ; alarme de destruction après 24 h d'inactivité (`agent.ts:15` et :36 à :48) ; `refreshTokenTTL` fixé à 30 jours non renouvelés (vérifié dans la bibliothèque 1.2.4 : `expiresAt` fixé à l'émission, pas de `refreshTokenIdleTTL`)

#	Constat initial	Statut	Vérification
M3	Données rattachées au login	**Corrigé, résidu MINEUR**	Session, props, clés KV, HMAC de domaine, clés de débit et quotas par id numérique. Résidu : `lib/identite.ts` migre encore les clés `<prefixe>:<login>` à chaque connexion (et `chiffrement.ts:72` `dechiffrerAncien`). Sans effet sur une base de production neuve, mais à retirer avant déploiement (tâche B14 déjà planifiée)
M4	Google Fonts sans consentement	**Corrigé**	Polices dans `public/fonts`, CSP `font-src 'self'` et `style-src 'self'` ; Chrome headless : aucune requête hors `localhost:8788` sur l'accueil, Confidentialité, Mentions légales, `/app`, `/app/studio`
M5	Information des personnes incomplète	**Corrigé, résidus MINEUR**	Base légale, tableau des traitements et durées, sous-traitants et transferts, âge minimal, contact privé, export, CNIL, voix Microsoft décrite. Résidus : N2, N3
M6	zod vulnérable, 13 vulnérabilités	**Corrigé**	`overrides` zod 4.6.7, undici 7.30.1 ou plus ; `npm audit` : 0 ; `osv-scanner` : aucune
m1	Email collecté sans usage	**Corrigé**	`Props` sans email, aucune occurrence de `user.email`
m2	Token non révoqué à la déconnexion	**Corrigé**	`auth.ts:72` à :82 (`DELETE /applications/{id}/token`). Expiration réelle des tokens de l'app : NON VÉRIFIÉ
m3	Captures : iframes, navigation tardive	**Partiel**	Redirection HTTP contrôlée, historique de navigation contrôlé avant et après la capture, scripts coupés avant la capture, iframes, objets et embeds retirés. Reste : images et fonds CSS d'autres origines affichables (pas de `Fetch.enable`)
m4	Floutage partiel	**Corrigé**	Pavé opaque, champs de saisie, `contenteditable`, shadow DOM ouvert, IPv6, téléphone ; limites documentées (`flou.ts:2`)
m5	Domaines jamais revérifiés	**Corrigé**	`domainesRevalides` : preuve rejouée après 7 jours
m6	`login` figé dans le Durable Object	**Corrigé**	Propriétaire enregistré et relu à chaque appel (`agent.ts:26`), en-tête `mcp-session-id` refusé s'il n'est pas dans `mcp:<id>` (`acces-mcp.ts`)
m7	Injection de prompt	**Corrigé, résidus N6 et N7**	`contenu_non_fiable` partout, rappel dans chaque description d'outil et chaque prompt, masquage des jetons connus, avertissement dans le skill vidéo
m8	Arguments du pipeline vidéo	**Corrigé**	`exigerNom`, `"--"` avant le texte de `say`
m9	`String.fromCharCode(...)` au-delà de 125 Ko	**Corrigé**	Encodage par blocs de 32 Ko (`chiffrement.ts:31`)
m10	Clé API lisible par JavaScript	**Corrigé (accepté)**	`sessionStorage` par défaut, avertissement « appareil partagé », recommandation de clé dédiée avec limite de dépense
m11	HSTS et COOP absents du front	**Corrigé**	`_headers` ; mesuré sur le serveur local ; page de consentement avec nonce, plus d'`unsafe-inline`
m12	Dépôt GitHub et outillage	**Partiel**	Faits : hooks versionnés (`core.hooksPath .githooks`, scan des secrets), actions épinglées par SHA, `cooldown` Dependabot, `.dockerignore` avec `/.env*` **et** `/.dev.vars`, image Docker en `USER node`. Restent : `main` non protégée (404), alertes Dependabot et mises à jour de sécurité désactivées (403), signalement privé désactivé

#	Constat initial	Statut	Vérification
m13	Email personnel dans les commits	**Ouvert**	Les 5 derniers commits portent encore l'adresse personnelle ; pas d'adresse `noreply` configurée
m14	Gestion de la clé racine	**Corrigé**	HKDF pour le HMAC, refus de démarrer sous 32 caractères, préfixe `v1`, AAD = clé KV
m15	Mineurs	**Corrigé**	Section « Âge minimal »
m16	`PUBLIC_URL` et id KV à finaliser	**Ouvert (déploiement)**	Toujours `http://localhost:8788` et `<Add-KV-ID>` ; noté dans `docs/installation.md:66`
m17	Dépendances de dev vulnérables	**Corrigé**	`npm audit` complet : 0

5. Points nouveaux vérifiés en priorité

Point	Statut	Vérification
`/api/voix` : validation	**OK**	Corps strict (`texte` 1 à 400 caractères, `scene` `[a-z0-9_-]{1,64}`), 64 Ko max, Origin, session, 60/min ; SSML échappé (`&`, `<`, `>`, caractères de contrôle), URL Microsoft fixe (pas de SSRF), délai 15 s, audio plafonné à 2 Mo
`/api/voix` : jeton Sec-MS-GEC	**OK technique, MINEUR N3**	Port d'edge-tts, aucun secret de Weekli ; usage non officiel
`/api/voix` : cache KV partagé et limite	**MINEUR N4**	Clé = SHA-256 de la voix et du texte ; 60 phrases par heure par compte ; cache non compté
Kokoro : CSP `wasm-unsafe-eval`, `worker-src 'self'`	**OK**	Aucun `eval` ni `new Function` dans le bundle ; modèles servis par le site, révision et SHA-256 épinglés (`scripts/modeles-voix.mjs`)
COOP et COEP	**OK**	En-têtes mesurés, `crossOriginIsolated` vrai dans Chrome
Lecture approfondie du tuto : plafonds	**OK, MAJEUR N1**	12 fichiers, 3 000 caractères, 24 000 au total, README 8 000, 100 Ko par fichier, 300 chemins ; mais masquage avant troncature et quadratique
Tuto : exclusions et secrets	**OK**	`.env*` (sauf exemples), `.dev.vars`, `.npmrc`, `.netrc`, clés, `credentials*`, `secrets.*`, `tfstate` ni lus ni listés ; dossiers de dépendances, générés, binaires écartés ; octet nul rejeté
Tuto : chemins choisis	**OK**	Seuls les chemins présents dans l'arbre et non écartés sont lus ; propriétaire toujours le login de la session ; repo privé refusé
Tuto : contenu non fiable	**OK**	Arborescence, fichiers, README sous `contenu_non_fiable`
`POST /api/posts/donnees`	**OK**	Validation stricte (`validerDemandePost`), 64 Ko, 401 sans session (mesuré), 403 sans Origin (mesuré)
`GET /api/repos/:repo/commits` et `fichiers-tuto`	**OK**	`NOM_REPO`, jours bornés 1 à 90, privé refusé, 401 mesuré
Outils MCP `preparer_post`, `proposer_post_projet`, `preparer_pub`, `sauver_pub`	**OK**	Identité relue à chaque appel, schémas zod, `nettoyerScriptPub`, limite de 20 pubs, lecture sous le login du token

Point	Statut	Vérification
Studio : IndexedDB	**OK, MINEUR N5**	Images et logo locaux seulement, jamais envoyés ; non effacés par « Supprimer mes données »
Studio : import d'images	**OK**	Type réel par octets magiques, 8 Mo (512 Ko pour le logo), redimensionnement à 2 560 px
Studio : SVG rastérisé	**OK**	Logo seulement, décodé via `<img>` (aucun script, aucune ressource externe), jamais injecté dans le DOM
Studio : export	**OK**	MP4, PNG, SRT en URL `blob:` locales
Effacement complet et export	**OK, MINEUR N5**	Voir M1 ; export `GET /api/moi/donnees` sans token, en pièce jointe
Pages Confidentialité et Mentions légales	**OK, MINEUR N2, N3, N8**	Comparées point par point au code (détail section 7)
Masquage des jetons	**MAJEUR N1, MINEUR N6**	Formats connus seulement (choix documenté)
Identité par id GitHub	**OK, résidu B14**	Voir M3
Mode démo absent du build	**OK**	`import.meta.env.DEV` en garde (`main.tsx:9`, `Tableau.tsx:22`, `lib/demo/installer.ts:127`) ; build recompilé avec `VITE_DEMO=1` : aucun module ni donnée de démo, assets identiques à `apps/web/dist` ; `apps/web/dist` actuel : aucune donnée de démo (seuls subsistent des noms de propriétés minifiés inatteignables)

6. Checklist complète

6.1 Code backend

Point	Statut	Comment
Injection SQL ou NoSQL	**OK**	Pas de SQL ; clés KV construites depuis la session
Injection de commande	**OK**	Aucune exécution dans le Worker ; scripts vidéo en `execFileSync` sans shell, noms validés
Path traversal	**OK**	Tuto : chemins de l'arbre seulement ; scripts vidéo validés
SSRF	**OK, MINEUR (m3)**	`global_fetch_strictly_public`, URL fixes (GitHub, DoH Cloudflare, Microsoft) ; captures limitées aux domaines vérifiés
Hash des mots de passe	Sans objet	Connexion GitHub uniquement
OAuth : PKCE S256, `state` lié au cookie, usage unique	**OK**	Lecture du code ; `plain` refusé (mesuré, 400) ; métadonnées `code_challenge_methods_supported: S256`
Consentement MCP avant GitHub	**OK**	`beginConsent` ; page échappée, CSP à nonce
Sessions : 256 bits, rotation, chiffrées, 8 h, index par compte	**OK**	`session.ts`

Point	Statut	Comment
Cookies `HttpOnly`, `Secure`, `SameSite=Lax`, `__Host-`	**OK**	En HTTPS ; en local `weekli_etat` mesuré `HttpOnly; SameSite=Lax`
Déconnexion et révocation GitHub	**OK**	m2
IDOR (API)	**OK (lecture)**	Aucune route ne prend d'id utilisateur ; brouillons et pubs filtrés dans la liste du compte ; NON VÉRIFIÉ dynamiquement (pas de session)
IDOR (MCP)	**OK (lecture)**	m6 ; NON VÉRIFIÉ dynamiquement
Validation des entrées	**OK**	64 Ko, `nettoyerPost`, `nettoyerScriptPub`, zod, regex de repo et SHA
Upload de fichiers	**OK**	Côté navigateur uniquement (type réel, taille) ; aucun upload serveur
CORS	**OK**	Aucun CORS sur `/api` ; `/mcp` reflète l'origine sans `Allow-Credentials` (jeton porteur) (mesuré)
CSRF	**OK**	403 mesuré sans Origin, Origin tierce, `null`, et `127.0.0.1` au lieu de `localhost`, sur `/api`, `/auth/logout`, `/authorize`
Limitation de débit	**OK**	Auth : 429 après 20 requêtes par minute (mesuré, `Retry-After: 60`) ; API 60/min/compte, captures 5/min (lecture)
En-têtes de sécurité	**OK**	Front : CSP, HSTS, COOP, COEP, nosniff, Referrer-Policy, Permissions-Policy (mesurés) ; Worker : nosniff, XFO DENY, Referrer-Policy, HSTS en HTTPS, `no-store` sur `/api` et `/auth`
401 sur les routes protégées	**OK**	14 routes testées, toutes 401 ; `/mcp` 401 avec `WWW-Authenticate` et métadonnées de ressource
Messages d'erreur	**OK**	Génériques ; pages OAuth sans détail interne (mesuré)
Journaux	**MINEUR (N2)**	Erreurs complètes journalisées à 4 endroits
ReDoS	**KO (N1)**	Mesuré

6.2 Base de données (KV, Durable Objects)

Point	Statut	Comment
Non exposée publiquement	**OK**	Services gérés ; nmap sans objet (aucun hôte déployé)
Privilèges minimaux	**OK**	Liaisons du Worker seulement
Chiffrement au repos	**OK**	Sessions, brouillons, pubs, style, domaines, index, token MCP ; audio vocal et compteurs en clair (non personnels ou peu sensibles)
Champs internes renvoyés	**OK**	`/api/moi` : id, login, nom, avatar ; jamais de token
Identifiants séquentiels	**OK**	UUID v4, 256 bits
Fichiers de base dans le dépôt ou par URL	**OK**	Aucun ; URL testées : repli SPA (N11)
Sauvegardes et restauration	*NON VÉRIFIÉ*	Aucune procédure ; KV sans sauvegarde native
Row Level Security	Sans objet	

6.3 Navigateur (Chrome headless, profil vierge)

Point	Statut	Comment
Secrets dans les bundles	**OK**	Motifs `sk-ant-`, `sk_live`, `pk_live`, `AKIA`, `AIza`, `ghp_`, `gho_`, `xox`, `eyJ` : aucun
Source maps	**OK**	Aucun `.map` produit ; `/assets/*.map` renvoie le repli SPA
Réseau	**OK**	Aucune requête tierce avant ou après chargement ; seule `/api/moi` (401) sur `/app`
Stockage	**OK**	`localStorage`, `sessionStorage`, IndexedDB vides sans action ; aucun cookie
Console	**OK**	Seulement l'erreur réseau attendue du 401
Fichiers exposés	**OK, MINEUR (N11)**	Aucun contenu sensible servi
XSS	**OK**	Aucun `innerHTML`, `eval`, `document.write`, `dangerouslySetInnerHTML` dans l'app ; React échappe
Scripts tiers, SRI	**OK**	Aucun script tiers
`target="_blank"`	**OK**	Aucun
Mode démo	**OK**	Section 5

6.4 Clés API

Clé	Statut	Comment
`GITHUB_CLIENT_SECRET`, `COOKIE_ENCRYPTION_KEY`	**OK**	Secrets Wrangler ou `.dev.vars` local non suivi ; aucune variable `VITE_` ; absents du bundle et de l'historique
`GITHUB_CLIENT_ID`	**OK**	Public par conception
Token GitHub de l'utilisateur	**OK**	Chiffré partout, jamais renvoyé au navigateur ni à Claude, absent de l'export
Clé API Anthropic	**OK par conception**	Navigateur vers `api.anthropic.com` seulement
Droits minimaux	**OK**	Scope `read:user`

6.5 Dépôt GitHub

Point	Statut	Comment
Historique complet	**OK**	46 commits, toutes branches
gitleaks	**OK**	3 résultats dans l'historique : jetons de test factices et constante publique edge-tts
trufflehog	**OK**	1 résultat non vérifié, URL de test factice
Fichiers sensibles suivis ou ayant été suivis	**OK**	Seul `.dev.vars.example`
`.dev.vars`	**OK**	Ni suivi, ni dans l'historique, ni poussé
`.gitignore`	**OK (choix)**	`.git/info/exclude` couvre `.dev.vars`, `.env*`, `node_modules`, `dist`, `.wrangler`

Point	Statut	Comment
Visibilité	Public	
Secret scanning et push protection	**OK**	Activés, 0 alerte
Dependabot alerts et mises à jour de sécurité	**KO (m12)**	Désactivées
Protection de branche	**KO (m12)**	`main` non protégée
CI	**OK**	`contents: read`, actions épinglées par SHA, `npm audit` en CI

6.6 Dépendances

Point	Statut	Comment
`npm audit`	**OK**	0 vulnérabilité (arbre complet et production)
`osv-scanner`	**OK**	Aucune sur 670 paquets
`semgrep`	**OK**	9 résultats, tous faux positifs ou sans risque : libellés constants (`donnees.ts:13`, `identite.ts:42`), valeurs échappées (`pages.ts:54`), XFO (`securite.ts:42`), échappement SSML de contenu (`voix.ts:25`), regex construite depuis un dictionnaire interne échappé (`prononciation.ts:45`)
Tests	**OK**	server 236, core 267, tous verts

6.7 RGPD

Point	Statut	Comment
Inventaire	Fait	Section 8
Minimisation	**OK**	Email retiré ; voix sans identité
Base légale	**OK**	6.1.b et 6.1.f indiqués
Cookies et traceurs avant consentement	**OK**	Aucun traceur, aucune requête tierce (mesuré)
Bandeau	Sans objet	Seulement des cookies nécessaires
Mentions légales	**OK, MINEUR (N8)**	
Politique de confidentialité	**OK, MINEUR (N2, N3)**	
Politique cookies	**OK, MINEUR (N2)**	Cookies OAuth non listés
Accès et portabilité	**OK**	Export JSON
Effacement	**OK, MINEUR (N5)**	Serveur complet ; stockage local partiel
Rectification, opposition	**OK**	Contact privé par email
Formulaires	**OK**	« Se souvenir de la clé » non coché ; pas de newsletter
Sécurité (article 32)	**OK**	HTTPS, chiffrement, accès restreint
Durées de conservation	**OK**	8 h, 24 h, 30 jours fixes, 90 jours ; entrées périmées retirées à la lecture
Transferts hors UE	**OK, MINEUR (N3)**	

Point	Statut	Comment
Mineurs	**OK**	

7. Pages légales comparées au code

Affirmation de la page	Code	Verdict
Session de 8 heures	`session.ts:8`	**Exact**
MCP : 30 jours non renouvelés, session technique effacée après 24 h	`conservation.ts:6`, `agent.ts:15`, bibliothèque	**Exact**
Brouillons, pubs, style, domaines : 90 jours renouvelés à l'écriture, retirés à la lecture	`conservation.ts`, `perimee`	**Exact**
Captures non conservées	`api.ts:350`	**Exact**
Voix : texte sans identité, audio 90 jours non rattaché	`voix.ts:41`, `:114`	**Exact**
Lutte contre les abus : 60 secondes	`voix.ts:119` (2 h)	**Incomplet (N2)**
Chiffrement AES-256-GCM avant KV	`chiffrement.ts`	**Exact**
Fichiers du studio dans IndexedDB, jamais envoyés	`cartes/chargement.ts`, `stockage.ts`	**Exact**
Clé API jamais envoyée au serveur	`generation.ts`, CSP	**Exact**
Deux cookies	Bibliothèque OAuth : trois de plus	**Incomplet (N2)**
Journaux sans donnée personnelle	`api.ts:54` et trois autres	**Inexact (N2)**
Effacement complet (grants, DO, autorisation GitHub, sessions)	`donnees.ts`	**Exact**
Export sans token	`api.ts:122`	**Exact**
Microsoft sous Data Privacy Framework	Aucun contrat	**À reformuler (N3)**
Contact, CNIL, âge minimal	Présents	**Exact**
Mentions légales : éditeur, contact, hébergeur et adresse	Présents, téléphone absent	N8

8. Inventaire RGPD des données personnelles

Donnée	Où	Pourquoi	Durée	Base légale
Id, login, nom, avatar GitHub	KV `session:*` (chiffré)	Compte, appels GitHub	8 h	Contrat
Token GitHub (`read:user`)	KV `session:*` ; grants OAuth (chiffrés) ; props du Durable Object (chiffré, AAD id)	Lire les repos publics	8 h ; 30 jours fixes ; 24 h d'inactivité	Contrat
Index des sessions et des Durable Objects	KV `sessions:<id>`, `mcp:<id>` (chiffrés)	Effacement complet	8 h ; tant qu'un DO vit	Contrat
Id, login, nom (props MCP)	Stockage du Durable Object (en clair, hors token)	Outils MCP	24 h d'inactivité	Contrat

Donnée	Où	Pourquoi	Durée	Base légale
Brouillons, pubs, style, domaines	KV par id (chiffrés)	Service	90 jours après la dernière écriture	Contrat
Texte et audio de voix off	KV `voix:<empreinte>` (non rattaché) ; Microsoft (transit)	Voix de la pub	90 jours	Contrat
Compteur vocal	KV `voix-quota:<id>:<heure>`	Plafond d'usage	2 h	Intérêt légitime
Adresse IP	Limiteur Cloudflare ; journaux Workers	Abus, diagnostic	60 s ; rétention Cloudflare	Intérêt légitime
Consentement mémorisé par client MCP	Cookie `__Host-oauth-approvals` signé	Ne pas redemander	30 jours	Contrat
Clé API Anthropic, réglages, dernier repo	Navigateur	Mode site	Onglet, ou jusqu'à effacement	Contrat (chez l'utilisateur)
Images, logo, modèle vocal, cache vocal	IndexedDB du navigateur	Studio	Jusqu'à effacement par l'utilisateur	Contrat (chez l'utilisateur)
Commits, diffs, README envoyés à Anthropic	Transit navigateur	Génération en mode clé	Selon Anthropic	Contrat, à l'initiative de l'utilisateur

Sous-traitants et destinataires : Cloudflare, Inc. (hébergement, KV, Durable Objects, Browser Run, DNS over HTTPS, journaux : États-Unis) ; GitHub, Inc. (identité et données : États-Unis) ; Microsoft (voix, sans contrat : États-Unis, N3) ; Anthropic (mode clé, depuis le navigateur : États-Unis).

---

9. Vérifications non faites

Vérification	Raison
Tests authentifiés (IDOR avec deux comptes, effacement réel, export réel, exploitation de N1, quotas vocaux)	Consigne : aucune session ni compte de Soufiane
Exploitabilité de N1 dans le runtime Workers	Nécessite une session ; coût CPU mesuré dans Node (même moteur V8)
Expiration réelle des tokens de l'app OAuth GitHub	Réglage du compte du propriétaire
Offre Cloudflare (quotas KV, limite de CPU)	Aucun compte consulté, rien n'est déployé
Réseau interne accessible depuis Browser Run	Infrastructure Cloudflare
Contenu réel des journaux Workers	Rien n'est déployé
nmap	Aucun hôte déployé
Sauvegardes	Aucune infrastructure
Webhooks du dépôt	Portée `admin:repo_hook` absente du token `gh`

10. Outils utilisés

Outil	Version	Usage
git	2.50.1	Historique, exclusions
gitleaks	8.30.1	Historique (`--log-opts=--all`) et arborescence, `--redact`
trufflehog	3.99.4	`git file://.`
semgrep	1.182.0	`p/default`, `p/typescript`, `p/secrets`, `p/github-actions`
osv-scanner	2.7.0	`package-lock.json`
npm audit	npm 11.16.0, Node 26.3.0	Arbre complet et production
gh	2.98.0	Réglages, alertes, protection, PR #6 (lecture)
curl	Système	Tests dynamiques non authentifiés (environ 70 requêtes au total)
Google Chrome headless + CDP	Système	Réseau, console, stockage, cookies avec un profil vierge ; conversion PDF
Vite	Projet	Build de production recompilé dans un dossier temporaire avec `VITE_DEMO=1`
vitest	Projet	503 tests

Aucun outil manquant. Mise à jour proposée : `brew upgrade semgrep`.

11. Vérification des corrections (2026-11-02)

Périmètre : commits `88b51af` (serveur et core) et `ce93c62` (web), relus avec `git show` et le code concerné ; mesures de performance et tests dynamiques non authentifiés (aucune connexion, serveur local laissé en marche, 9 requêtes). Aucun code modifié.

#	Statut	Preuve
N1	**CORRIGÉ**	Mesures sur 18 textes hostiles de 200 Ko (sk-sk-, sk-ant-, sk-a1, ghp_, github_pat_, Alza, npm_, glpat-, SG., AKIA, xoxb-, sk_live_, PEM sans fin, PEM répétés, tirets, un seul sk- de 200 Ko, etc.), Node 26.3.0 (V8) : masquerSecrets sur les 200 Ko entiers, 0,4 à 2,3 ms ; masquerEtTronquer avec plafonds 3 000, 6 000, 8 000, 24 000 et 100 000 : 0 à 1,1 ms. Le pire cas est 2,3 ms, contre 8 514 ms avant. Le motif sk- n'a plus d'anticipation (le contrôle du chiffre est dans la fonction de remplacement). Troncature avant masquage (plafond + 256 de marge) sur tous les chemins : fichiers du tuto (tuto.ts:140), README du tuto (tuto.ts:151), README de detailsRepo (github.ts:125), patchs de commit (github.ts:158). Aucun autre appel à masquerSecrets dans le code de production. Tests vitest masquage, tuto, prompts : verts.
N2	**CORRIGÉ**	Confidentialite.tsx comparée au code : trois cookies OAuth listés avec durées (10 minutes, 30 jours) ; quota vocal 2 heures ajouté au tableau ; journaux décrits comme pouvant contenir l'adresse d'une requête GitHub ou d'une page capturée, ce que font api.ts:54, auth.ts:65, oauth-mcp.ts:38 et outils-captures.ts:33. L'affirmation « jamais ton token » tient : RequestError d'Octokit remplace l'en-tête d'autorisation par [REDACTED] (node_modules/@octokit/request-error/dist-src/index.js:31). Cookies conformes à la source de la bibliothèque comme relevé le 29 octobre.
N3	**CORRIGÉ**	Microsoft présenté comme « service tiers, pas un sous-traitant, aucun contrat, usage non officiel », sans mention du Data Privacy Framework (grep : le cadre UE-États-Unis ne reste que pour Cloudflare et Anthropic). La ligne sur le choix « Kokoro, Ma voix, Sans voix » pour ne rien envoyer est exacte. Reste la décision de fond (Azure Speech avant ouverture publique), hors périmètre du code.

#	Statut	Preuve
N4	**PARTIEL**	api.ts:279 : le quota (reserverPhrase) est désormais compté avant la lecture du cache, donc les réponses servies par le cache consomment les 60 phrases par heure : le sondage est borné à 60 par compte et par heure (avant : illimité). TTL du cache ramené à 30 jours (voix.ts:107). Résidus : un cache partagé reste sondable par la latence (réponse immédiate contre synthèse), ce que le commentaire du code ne supprime pas ; l'écriture KV reste possible jusqu'à 60 par heure et par compte (1 440 par jour), et l'offre Cloudflare (1 000 écritures par jour en gratuit) n'est pas vérifiée. Tests voix et durcissements : verts.
N5	**CORRIGÉ**	reglages.ts : effacerDonneesLocales supprime weekli.cle, weekli.prefs et weekli.dernierRepo dans localStorage et sessionStorage, puis les bases IndexedDB weekli-pub (lib/pub/cartes/stockage.ts:24) et weekli-voix (lib/voix/cache.ts:4), qui sont les deux seules bases ouvertes par le code web (grep indexedDB.open). Les trois clés weekli.* du code sont couvertes. Le serveur est effacé d'abord, une erreur locale est signalée et relançable. Texte du panneau aligné (session 8 h, autorisation Claude 30 jours, pubs, audio serveur 90 jours). reglages.test.ts : vert.
N6	**PARTIEL**	detailsRepo masque et tronque le README (github.ts:125). Formats ajoutés et vérifiés par exécution : sk_live_ et rk_live_, AIza, npm_, glpat-, SG. : tous remplacés par [secret masque] ; sk-learn-... (sans chiffre) conservé, sk- avec chiffres masqué. Les JWT (eyJ...) cités dans le constat ne sont toujours pas masqués (vérifié). Ces contenus sont déjà publics sur GitHub : impact très faible.
N7	**CORRIGÉ**	prompts.ts:131 : tous les « < » du JSON sont remplacés par la notation JSON u003c. Test prompts.test.ts:42 à 46 (le contenu « </donnees_post> » ne produit qu'une seule balise fermante) : vert.
N8	**CORRIGÉ**	MentionsLegales.tsx:24 : téléphone de Cloudflare, Inc. ajouté (+1 888 993 5273, lien tel:). Le numéro est le numéro public connu de Cloudflare, non revérifié en ligne.
N9	**CORRIGÉ**	github.ts:136 à 140 : detailsCommit lit aussi repos.get et lève une erreur si infos.private, comme commitsRepo et detailsRepo.
N10	**CORRIGÉ**	wrangler.jsonc : « limits »: { « cpu_ms »: 5000 }. Effet réel au déploiement non vérifié (rien n'est déployé). Avec N1 corrigé, le plafond n'est plus qu'un garde-fou.
N11	**CORRIGÉ**	Serveur local 8788 relancé depuis le 29 octobre, tests non authentifiés (curl, 9 requêtes) : /.env, /.git/config, /.dev.vars, /.DS_Store, /.hidden : 404 JSON de 24 octets avec X-Frame-Options et nosniff ; /.well-known/oauth-authorization-server et /.well-known/oauth-protected-resource/mcp : 200, métadonnées OAuth intactes (le motif « /.* » n'a rien cassé) ; /backup.sql et /server-status : 200 repli SPA de 783 octets, sans contenu (hors du constat, qui ne visait que les chemins à point). Route /api/moi sans session : 401.

En-têtes de la page d'accueil (curl -I, localhost:8788) : Content-Security-Policy stricte (default-src 'self', frame-ancestors 'none', connect-src limité à self et api.anthropic.com), Strict-Transport-Security, Cross-Origin-Opener-Policy same-origin, Cross-Origin-Embedder-Policy require-corp, Permissions-Policy, Referrer-Policy strict-origin-when-cross-origin, X-Content-Type-Options nosniff. Pas de X-Frame-Options sur la page HTML (frame-ancestors couvre le besoin, présent sur les réponses du Worker). Aucune régression par rapport au 29 octobre.

[MINEUR] N12. apps/server/rangler.jsonc : fichier vide ajouté par erreur dans le commit 88b51af (faute de frappe sur wrangler.jsonc, 0 octet, suivi par Git). Sans effet de sécurité, à supprimer (agent : backend-senior).

Aussi constaté : l'arbre de travail contient des modifications non commitées hors périmètre de cette vérification (Confidentialite.tsx, useVoixPub.ts, PanneauVoix.tsx, Editeur.tsx, voix.test.ts, suppression de demo/weekli-pub.png). Le diff de Confidentialite.tsx ne change que le texte sur le choix de voix, sans effet sur les constats ci-dessus.

Verdict final mis à jour

Corrigés : N1 (le MAJEUR), N2, N3, N5, N7, N8, N9, N10, N11 (9 sur 11). Partiels : N4, N6 (résidus très faibles). Nouveau : N12 (MINEUR). Reste de l'audit du 29 octobre inchangé (m3, m12 partiels ; m13, m16 ouverts ; B14).

Verdict global mis à jour : OK, avec réserves MINEUR : 0 BLOQUANT, 0 MAJEUR. Les vérifications impossibles listées en section 9 (tests authentifiés, déploiement, quotas Cloudflare) restent non faites et ne sont pas comptées comme réussies. Cet audit technique ne remplace pas l'avis d'un juriste ou d'un DPO.